复习笔记

第一章　网络安全概述

网络安全概念与目标

网络安全

网络系统的 **硬件、软件及系统中的数据** 收到保护，不因偶然的和恶意的原因而遭受 **破坏、更改和泄露**，系统能够 **连续、可靠、正常** 地运行，网络服务保持不中断。

👉 网络系统安全 + 网络信息安全

🥷 世界上不存在绝对安全。提高安全性通常要**消耗性能、资源和成本**，因此现实目标是根据风险和业务需要，把风险降到可接受程度。

网络安全目标

- **保密性**：网络信息不被泄露给**非授权**用户或实体，也不供其利用。常见实现方式包括加密、身份认证和访问控制。
- **完整性**：网络信息未经授权不能改变；在传输、交换、存储和处理过程中不被修改、破坏或丢失。
- **可用性**：授权实体能够按需求访问和使用**网络信息或服务**。系统"数据还在但服务打不开"，依然是安全问题。
- **可控性**：对网络信息的内容及传播具有控制能力，关注信息在**传输范围**和**存放空间**中的可控程度。
- **可审查性**：通信和操作应留下可调查的依据，使相关主体**难以否认**已经发送、接收或实施的行为。课件用该词涵盖**追踪**、**核查**和**不可抵赖**的含义。

安全内容威胁与漏洞

网络安全内容

- **实体安全**：环境、设备、介质（防火、水灾、地震、有害气体和环境事故）
- **系统安全**：网络、操作系统、数据库（安全策略、保障措施、规范、应急修复）
- **运行安全**：系统运行与访问控制（监测、隔离、补丁、审计、灾备、检查评估）
- **应用安全**：应用平台与业务数据（可靠性测试、访问控制验证、数据备份恢复、程序安全分析）
- **管理安全**：人员、制度、标准和流程（法规、政策、培训、操作、文档、机房和运营管理）

👉 技术（外部攻击） + 管理（内部人为因素）

> **Important**
>
> **为什么管理安全不能被技术安全替代?**
>
> 技术措施不能消除人员违规、制度缺失、培训不足和流程失效，需要管理措施统一协调。

网络安全威胁

👉 网络本身不可靠性和脆弱性 + 人为破坏

- **物理威胁**：有意或无意的物理破坏（断电、火灾、设备损毁）
- **操作系统缺陷**：默认服务、端口、配置或程序缺陷（默认开放端口、无认证服务）
- **网络协议缺陷**：协议设计时安全考虑不足（TCP/IP 及上层协议受基础缺陷影响）
- **体系结构缺陷**：系统设计或实现中的结构问题（小型编程缺陷破坏整体安全）
- **黑客程序**：用于远程攻击、控制、窃取和破坏的软件（攻击工具、远控程序）
- **恶意代码**：违背安全策略并造成泄露、滥用或破坏的代码（病毒、破坏性样本；特点是非授权和破坏性）

> ⚠ **Caution**
>
> **操作系统缺陷 & 体系结构缺陷**
>
> - 操作系统缺陷：在 OS 层面的默认服务、端口、权限、认证、补丁或程序漏洞。
> - 体系结构缺陷：偏系统整体设计、模块关系、信任边界、权限结构等设计层面的弱点。
>
> 🥷 操作系统缺陷是“底层平台具体哪里有毛病”，体系结构缺陷是“整体设计方式有先天弱点”。
>
> **黑客程序 & 恶意代码**
>
> - 黑客程序：偏“攻击工具”，重点是被人用来入侵、远控、扫描、窃取或破坏。
> - 恶意代码：偏“代码本身带有非授权、破坏、泄露或滥用意图”，如病毒、蠕虫、木马、勒索软件。
>
> 🥷 黑客程序强调“工具用途”，恶意代码强调“代码性质”。

网络安全漏洞

🥷 不存在绝对安全，只能把风险降到可接受程度。

硬件、软件、协议具体实现、系统安全策略或人为因素中的缺陷，使攻击者能在未获合法授权时访问或破坏系统。

- 操作系统漏洞
- 网络协议漏洞
- 网络服务漏洞
- 数据库漏洞

> ⚠ **Caution**
>
> **威胁 & 漏洞**
>
> 威胁：什么因素可能造成损害
>
> 漏洞：系统哪里存在可被利用的缺陷
>
> 🪄 威胁像“小偷”，漏洞像“没锁的窗”，风险是“小偷从窗户进来造成损失的可能性和后果”。

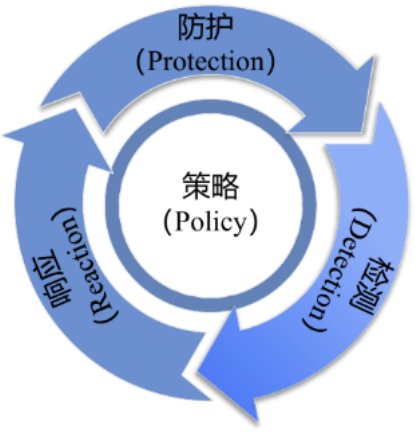
安全模型与评估准则

网络安全模型

1. **P2DR安全模型**

   美国国际互联网安全系统公司（ISS）提出，动态网络安全体系代表模型。

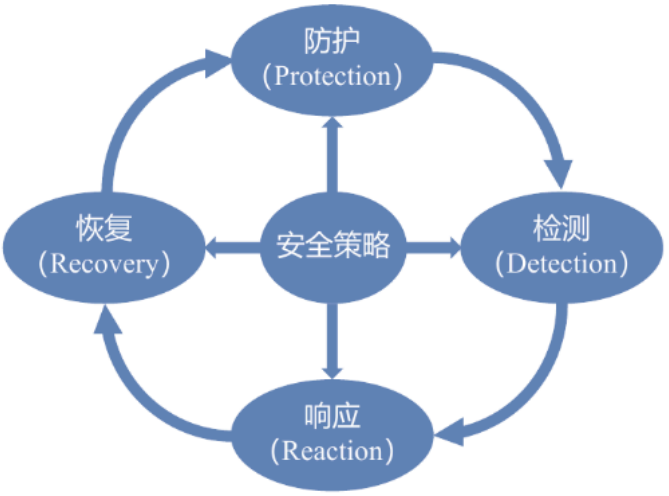
   核心结构：**Policy（策略）**统领 Protection（防护）、Detection（检测）、Reaction（响应），再回到防护循环。



2. **PDRR模型**

   美国国防部提出，公认的比较完善且有效的网络信息安全解决方案。

   核心结构：Protection（防护）→ Detection（检测）→ Reaction（响应）→ **Recovery（恢复）** → 防护，安全策略贯穿各环节。



3. **MPDRR 安全模型**

   具有纵深防御体系的网络安全模型，在 PDRR 基础上加入管理，将技术和管理融为一体，整个安全体系的建立必须经过安全管理进行统一协调和实施。

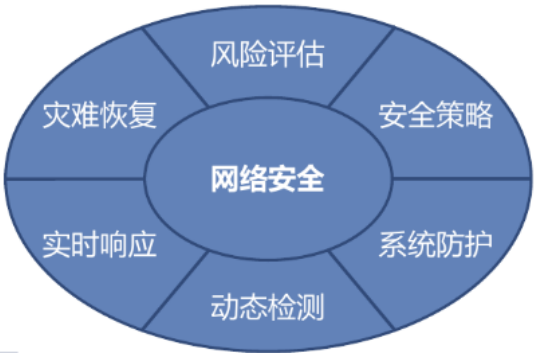
   核心结构：Protection（防护）→ Detection（检测）→ Reaction（响应）→ Recovery（恢复）→ **Management（管理）** → 防护，安全策略贯穿各环节。



4. **APPDRR 安全模型**

   六个部分：**Assessment（风险评估）**、Policy（安全策略）、Protection（系统防护）、Detection（动态检测）、Reaction（实时响应）、Recovery（灾难恢复）。

   👉 **风险评估是起点，策略承上启下。**



网络安全评估准则

1. **TCSEC 美国 “橙皮书”**

   1985年，国际公认的第一个计算机系统安全评估准则，4类7级，D→A

等级	名称	关键增量
D	最低安全保护级	无实际安全措施
C1	选择性/无条件安全保护	登录认证、访问权限限制
C2	有控制的访问保护	增加审计、访问保护和跟踪
B1	标记安全保护	增加数据标记
B2	结构安全保护	所有对象标记并分配安全级别
B3	安全域保护	以硬件等手段加强安全域
A	验证安全保护	最高级，包含低级别特性并强调验证

2. **ITSEC**
3. **通用准则CC**

4. **信息系统安全保护等级**

   国内安全评估准则

   - 用户自主保护级
   - 系统审计保护级
   - 安全标记保护级
   - 结构化保护级
   - 访问验证保护级

安全策略与关键技术

网络安全策略

- **物理安全策略：**保护硬件和链路、验证身份权限、保证环境兼容、建立机房制度
- **信息加密策略**：保护存储和传输数据
- **访问控制策略**：防止网络资源被非法使用和访问，核心策略之一
- **安全管理策略**：通过规章制度保证安全、可靠运行

网络安全关键技术

1、**三大类：**

- **预防保护类：**事前，鉴别、加密、访问控制、防火墙
- **检测跟踪类：**事中，入侵检测、监控、审计跟踪
- **响应恢复类：**事后，应急响应、备份恢复

2、**关键技术：**

- **鉴别技术：**通信双方身份，数据完整性
- **加密技术**：重新编码隐藏真实内容
- **访问控制技术：**授权用户在权限内使用授权资源
- **恶意代码防范技术：**预防、检测、隔离和清除
- **防火墙技术：**两个网络之间访问控制
- **入侵检测技术：**运行中检测
- **加固技术：**对漏洞和隐患进行防护
- **监控技术：**用户主体的访问行为
- **审计跟踪技术：**核查、记录和追踪异常访问与操作
- **备份恢复技术：**预先备份，意外后恢复系统和数据

> **Caution**
>
> **防火墙 & 访问控制**
>
> 防火墙：在**网络边界**执行访问规则

> 访问控制：限定主体对资源的权限

黑客与攻防关系

不能仅凭自称目的认定为白帽。应判断**是否有明确授权**、**是否超出授权范围**、**真实目的**、**采取的行为**、**是否查看或影响数据**、**披露与处置方式**及**后果**。